Legal Challenges in IOT

Vulnerability Concerns and Groundwork for Legal Challenges

Despite the many benefits of IoT, increased connectivity between devices and the Internet tend to create an array of security and privacy risks. The complexity and connectivity commonly found in IoT introduces new security vulnerabilities. Government and corporates are worried that the proliferation of cheap IoT devices and their applications can create security issues for consumers in terms of data collection and purpose of use.

IoT devices are prone to many vulnerabilities as they can be used to direct attacks (such as denial of service) on the consumer's network. Smart televisions store or transmit information that could be exploited by hackers to compromise personal information. A hacker could attack one of the consumer's interconnected devices which not only provides him with access and control of the devices such as video cameras, sensors, or smart light bulbs, but also provides him with the opportunity to gather all manners of personal information. The reality is that consumers' concerns regarding their safety, privacy, and data security trump their fascination with IoT devices.

The U.S. Department of Homeland Security (DHS) asserts there is no clear understanding of who is responsible for security decisions in a situation in which one vendor designs a device, another supplies component software, another organization operates the network in which the device is embedded, and another deploys the device. It argues that this challenge is amplified by lack of comprehensive widely adopted international norms and standards for IoT security, lack of incentives for developers to adequately secure products and unequal awareness of the methodology of evaluating security features of competing options. Digital goods have moved away from the traditional legal models as IoT manufacturers and distributors are gradually shifting the rules of ownership and as such, there is a blurry line as to who actually owns our IoT devices such as phones, refrigerators, cars and televisions. The question asked is whether the purchasers are merely licensing these devices. This issue has generated different schools of thought. While some IoT device manufacturers assert that it is illegal for anyone other than the device manufacturer to diagnose and fix the problem when our devices breaks, others claim that they own any data generated by the device and not the users who purchased the device and created the data. As user and consumer advocates continue to polarize these assertions, device manufacturers continue to advance this cause.

The battle of who "owns" the device continues to gather momentum with Apple insisting that "iPhone users are licensees, not owners, of the copies of the iPhone operating software". Elsewhere, vehicle manufacturers such as John Deere, Ford, General Motors, Mercedes Benz, and Ferrari have resorted to using technology and law to weaken property interests of drivers. For example, newer John Deere tractors contain at least eight control units – software and hardware

components that regulate various functions that no longer allow farmers to maintain and repair their own equipment other than to send them to the factory. The tractor manufacturer is said to have interposed the firmware between the farmers and the tractor, claiming ownership of the vehicle while relegating the farmers as merely having "an implied license for the life of the vehicle to operate the vehicle". In 2015, Ford recalled 433,000 new cars and SUV vehicles due to software glitches that could allow the vehicle to continue running the engine after turning the ignition key to the "off" position, and which could also allow the vehicle be rolled away or be stolen. In 2015, Chrysler recalled 1.4 million vehicles due to hackable vulnerability on the vehicles' Uconnect dashboard computers which could result in the hackers taking over the dashboard functions, steering, brakes and transmissions.

The vulnerability of IoT devices and products were actually encouraging attacks against consumers. A 2015 Hewlett Packard report on home security systems (motion detectors and video cameras) showed that 100 percent of the devices studied contained significant vulnerabilities such as password security, encryption, and authentication issues. Its report the previous year had indicated 70 percent of IoT devices were susceptible to attacks such as password security, lack of user access and encryption.

Ukraine's power grid has been attacked twice in between 2015 and 2016. The 2015 cyberattack on Ukraine's power grid was as a result of BlackEnergy malware found on the computer systems of the affected power companies and caused power outage for several hours. The hackers had used malicious firmware to replace the legitimate firmware in the serial-to -Ethernet converters at many substations which gave them access to SCADA network through the hijacked Virtual Private Network. This allowed the hackers to successfully launch commands that disabled the Uninterruptible Power Systems they had earlier reconfigured while rendering the converters inoperable and unrecoverable. The DHS attributed the malware as being directed to attack Ukraine's obsolete and vulnerable industrial control systems.

The damage could have been worse and Ukraine's saving grace was the antiquated technology was not Internet connected, allowing companies to restore power within a short period of time. The second Ukraine attack in 2016, which also resulted in power disruption was allegedly masterminded by Russian hackers who compromised some computers at an electricity control center to plunge parts of the city of Kiev into darkness. The hackers were said to have sent malware to the employees via e-mail which in turn facilitated the stealing of the login credentials to shut down the substations.

Liabilities and Class Action Suits

In March 2015, the first IoT class action was instituted against three giant automakers – Ford Motor Company, General Motors and Toyota Motor Corporation at the U.S. District

Court for the Northern District of California on the backdrop of a report released by U.S. Senator Edward Markey.

In Cahen et al. vs. Toyota Motor Corporation, 147 F.Supp.3d 955, N.D. Cal. It was alleged that some models of their vehicles had defective electronic systems that were vulnerable to remote hacking and which had a potential of compromising safety and personal information. Investigations had revealed that hackers could hijack the controls of the affected vehicles from the driver to cause unexpected acceleration, loss of breaks, turns, horn activation, modification of the speedometer and gas readings. However, the case was dismissed and also upheld at the 9th Circuit of the U.S. Court of Appeals based on jurisdictional grounds and lack of standing as the plaintiffs could not prove any actual injury or any immediate threat of injury.

In July 2015, Fiat Chrysler faced a class action suit in the U.S. District Court for the Southern District of Illinois after recalling 1.4 million of their vehicles affected by a hackable software in Chrysler's UConnect dashboard. The UConnect consists of software and hardware components which control Bluetooth phone, navigation and entertainment systems. It was alleged that hackers could gain control of the radio and air-conditioning features and the entire vehicle via the vehicle's input and USB port. The publication of vulnerabilities of automobiles to Internet hacking gingered U.S. Senators Edward Markey of Massachusetts and Richard Blumenthal of Connecticut to introduce "legislation that would empower the US National Highway Traffic Safety Administration (NHTSA) and the Federal Trade Commission to secure vehicles from hacking threats and main driver privacy".

Other IoT-based class action suits have followed. In 2015, a class action suit was brought against Mattel, ToyTalk, and kidSAFE – makers of the high-tech, talking Barbie doll by parents who claimed that a security flaw with the doll allowed hackers to compromise their children's privacy. The parents alleged that the 'Hello Barbie' doll collects personal data that could be easily compromised by hackers. VTech, another toy manufacturer was hit with a class action suit in 2015 over its failed effort to safeguard personally identifiable information (PII) of about 10 million American children and the parents. The hackers compromised personal information (names, birth dates, gender, e-mail addresses and profile names) of the children and their parents. VTech provides the software that allows parents to limit children's Internet access and to track their learning achievements through the "Learning Lodge"

Deconstructing the Legal Challenges

To illustrate how IoT controls our daily lives, an examination of a Breathometer, which was a device used to measure the blood alcohol content of users by using their iOS (iPhone operating system) and Android smartphones is helpful. Breathometer is representative of devices that promise efficiency, social, and individual benefit via quantification and monitoring of once immeasurable qualities. A consumer purchases this device, unpacks it, and reads the user's manual

that elaborates how to download the Breathometer app, creates an account with the company via the app, and then plugs the device into her smartphone. However, the manual does not contain any information about privacy policy that might apply to the data generated by the device. Nor is there any description or explanation of what data the device will generate, where such data will be stored (such as user's phone or company's server in the cloud); whether such data can be erased and how; how the company might use such data, if the company will sell it or could it be required by a court? When installing the Breathometer app through the Apple App Store, there is no mention of any privacy policy. No pop-up message with such a policy appears when the user creates her account via the app or starts using the device.

It is only when the purchaser then logs into the company's website, scrolls down the bottom and clicks the small link for "Privacy Policy" can she learn that her blood alcohol test is being stored indefinitely in the cloud, and cannot be erased by the user, may be disclosed in a court proceeding if necessary, and may even be used to moderate advertisements at the company's discretion. Has anyone pondered the employment decisions; criminal liability implications; and health, life or insurance ramifications this data could generate? How much power and information has the user or consumer given up to the Breathometer company?

On the surface, the consumer has been misled to assume the Breathometer is a small black device like any other device, not knowing it is a data source and cloud base repository. Now, imagine when the device is stolen or the data generated and stored on this device falls into the hand of criminals. The description of the Breathometer highlights the real challenges of IoT in terms of what information do these devices collect, how would such information be used, what real choices do consumers have about such data, and who owns the data?

Current Legal Problems

It is evident that consumer devices such as home and appliance monitors, automobile black boxes, personal health monitors, smartphones and employee monitors generate huge amount of valuable data about their users' activities, habits, personalities, preferences and attributes. This goes to expose the grave dangers of these IoT devices despite their flurry of benefits to mankind.

The use of IoT devices presents four legal problems - (1) discrimination, (2) privacy, (3) security, and (4) Consent.

1. *Discrimination*

The widespread deployment of sensor poses both technical and legal problem for IoT because IoT data allows consumers to be sorted and discriminated against. Data collected by IoT devices can be used for both beneficial and discriminatory purposes as exemplified in the case of personal wearable fitness tracker which continuously tracks detailed information about the person's movement and biometric data. This data can be analyzed to determine the person's level of fitness,

estimate calories burned, track hours left, which then will be used to characterize the quality of sleep and sleep pattern. The data can also reveal the person's disordered eating behavior, insomnia, diabetes, cigarette smoking, or alcohol and drug abuse.

The sensor data from IoT devices can provide unexpected information about individual consumers which allows employers, lenders and insurers use this data to draw inferences and make economically important decisions, without the industry regulators or consumers having knowledge or understanding of the process. The data can provide huge amount of the person's information to her prospective employer or insurance company which may also be used to deny her employment or application. The current antidiscrimination and credit reporting law is unprepared to handle IoT-based discrimination in which consumer information is revealed. Two legal concerns arise from the possibility of indiscriminate exposure of information.

- First, will IoT lead to new forms of discrimination against protected class, such as race, age or gender?
- Two, will IoT lead to disturbing forms of economic discrimination? This type of discrimination will open doors to new patterns of illegal discrimination against age, race or gender and may also trigger class action lawsuits.

2. Privacy

Privacy is meant to respect customer's information and their rights to determine how such data is used. Accountability, a key privacy principle is difficult to keep with IoT generated data because of the involvement of multiple stakeholders such as device manufacturers, third party applications and social platforms who collect, use or exposed data. IoT can jeopardize a person's expectations of privacy in many ways as shown in Riley v. California.

The case raised a common question of whether the police may, without a warrant, search digital information on a cell phone seized from an individual who has been arrested. Riley was stopped by a police officer for driving with expired registration tags. In the course of the stop, the officer also learned that Riley's license had been suspended. The officer impounded Riley's car per department policy, conducted a search which revealed possession of concealed and loaded firearms and two handguns. Riley was arrested and his cell phone was seized and upon examination of its content, the police found pictures of Riley standing in front of a car they suspected had been involved in a shooting a few earlier. Riley was finally charged, in connection with earlier shooting, with firing at occupied vehicle, assault with a semiautomatic firearm, and attempted murder.

The U.S. Supreme Court ruled that information on cell phone is not immune from search, but the Police must obtain a court search warrant before searching a cell phone seized incident to an arrest. Although Justice Alito concurred to the decision, he stated that the rule of pre-digital era should not be used in searching a cell phone and called for a new balancing of law enforcement and privacy interest. His opinion was that privacy protection in the 21st century should not be left

primarily in the hands of the federal courts using the blunt instrument of the 4th Amendment, citing it as the prerogatives of Congress and state legislations

It is clear that Riley's cell phone information linked him to shooting and attempted murder charges and also led his 4th amendment violation. Mobile phones contain huge amount of data such as videos, photographs, phone book, calendar, text messages and Internet browsing history, bank statements, medical information, and other sensitive documents which have interrelated consequences for privacy. Although IoT devices such mobile phones, digital cameras and GPS can be beneficial to law enforcement agents in tracking criminals, the manner they are used can also violate consumer's privacy (Rose et al., 2015). The problem is how to encourage or compel IoT manufacturers to integrate privacy-by-design and security-by design principles into their core values and how device functionality and privacy requirements can be reconciled; Congress is needed to enact appropriate legislations in this direction.

3. Security

Data collected from IoT devices may not be restricted from being sent across jurisdictional boundaries as these devices communicate via the Internet, and the Internet spans different jurisdictional boundaries. IoT devices can collect people's data in one jurisdiction, transmit and store that information in another jurisdiction for processing and storage. This can become a legal problem if the data collected is private and sensitive and subject to data protection laws in multiple jurisdiction. Encryption may be a requirement in one jurisdiction but not required in another jurisdiction.

For example, consider a Fitbit monitoring device collecting a consumer's information in the United States and storing the data in the organization's Web server in Switzerland. More complications arise when the data protection laws in United States where the device and data physically reside may not be consistent or compatible with the laws of Switzerland where the data is stored and hosted on the Web server. Trans-border data flows raise questions about the legal scope of regulations that may be applicable. In this situation, it may be difficult to isolate which law governs the device collecting the data in USA, and which law that governs the storage and use of the collected data in Switzerland. The question becomes whether a jurisdiction with more-restricted data protection (such as encryption and strict access controls) laws for handling and transmission of IoT-enabled data be able to project such legal requirements onto other jurisdictions. This is a new challenge that IoT devices pose because the devices can automatically connect to other devices and systems and transmit data across international borders without the knowledge of the user. This creates a liability for cross-border data flow requirements.

IoT devices may be prone to security flaws and the devices may not be patchable or easy to update and thus get exposed to hacking; insulin pumps have been reported to be exposed to hacking. Data security law is unprepared for IoT security problems. For example, in US, the FTC

enforcement and state data breach notification laws regulate data security in the United States. Neither of these laws is clearly applicable to breaches of IoT data as there is no general federal data-security statute yet, prompting FTC to use its general authority under the FCT Act to institute penalties against companies with security negligence. There are also considerations of IoT security violations under state data-breach notification statutes.

4. Consent

Discrimination, security and privacy issues about IoT underline the new and exclusive ways in which connected sensor devices could harm the wellbeing of consumers. IoT devices complicate consent as they do privacy, security and discrimination. Consumer protection laws associated with privacy-policy disclosures is currently not prepared to tackle with these issues. Sensor devices pose a threat to consumer consent. IoT devices are screen-less and lack an input mechanism such as a keyboard or touch screen. IoT device manufacturers prefer to provide privacy and data-related information in website privacy policies. The ambiguity of IoT privacy policy language further compound issues in the sense that there is no clear policy understanding of whether sensor or biometric data count as personal information and how such data can be shared with or sold to third parties. Consumer protection law is unprepared as most regulator's authority is to guard deceptive and unfair practices. IoT data are difficult to anonymize and secure and this creates some privacy issues

IoT Device Liability and Concerns Regarding Data Security and Privacy

IoT devices pose legal liability concerns that need consideration. The fundamental question regarding IoT devices is: Who is responsible if a person is harmed as result of an IoT device's action or inaction? There is not much case law to support this position which has led to a barrage of questions. Currently, there is no defined statute as to who owns the data generated and collected by IoT devices – consumers or device manufactures? There are also concerns as to who is responsible or liable for patching IoT devices, routers, switches and cloud connections as well concerns if the user can view, edit, or delete sensor data from the manufacturer's servers if it is stored there. Does the IoT device have security controls built-in? Is device information encrypted and how?

Questions are asked about what exact information the device will collect about itself or its user, using what sorts of sensors? Is that information stored in the device itself, on the user's smartphone, on the manufacturer's servers in the cloud, or all of the above? Where will the information be stored? Does the device support an industry or regulatory function? What data will the device disseminate and what kind of security controls can the IoT device support?

Consumers wonder if there are situations where IoT devices should not be collecting data and who exactly will the manufacturer or service share the data with, and whether the user have any right to opt out of such disclosures? Can the user gain access to the raw sensor data in order to export it

to another service or device and what happens if the IoT product vendor goes out of business or no longer supports the product? What happens when the Internet connection goes down?

Issues have also been raised regarding if a cloud-based IoT device termed “remote computing service” is protected by the data protection Act? What is the classification of the data and risks associated with it being transported? What is the intended useful life of the device? Are proprietary accesses needed for updates and maintenance? These are legitimate concerns and questions that continue to trail the adoption, growth and development of IoT unless legislative bodies and device manufacturers properly address them.